Thor's Quick Sheets - CC® Domain 2

Contents

BCP – Business Continuity Plan 2

DRP – Disaster Recovery Plan 3

BIA – Business Impact Analysis 3

Recovery Strategies 4

Incident Management 5

BCP – Business Continuity Plan

Purpose:

- Long-term strategic plans for continued operation post-disruption.
- Covers the entire organization, not just IT.

Components:

- Disaster scenarios and recovery steps.
- Includes COOP, Crisis Communications Plan, DRP, ISCP, OEP.
- Iterative process, written with key staff and consultants.

Senior Management Role:

- Must be involved in initiation and approval.
- Responsible for plan implementation and prioritization.

Related Plans:

- **COOP**: Ensure operations continue during a disaster.
- **Crisis Communications Plan**: Communication strategies during a crisis.
- **Cyber Incident Response Plan**: Respond to cyber events (e.g., DDOS, viruses).
- **OEP**: Protect facilities and personnel (e.g., fires, floods).
- **BRP**: Steps to restore business operations post-disruption.
- **Continuity of Support Plan**: Support specific IT systems.
- **CMP**: Coordinate management actions during emergencies.

Older versions of **NIST 800-34** had these steps as a framework for building our **BCP/DRP.**

- **Project Initiation**: Identify stakeholders, get approval.
- **Scope the Project**: Define goals and boundaries.
- **Business Impact Analysis**: Prioritize critical systems.
- **Identify Preventive Controls**: Assess and deploy controls.
- **Recovery Strategy**: Develop recovery options.
- **Plan Design and Development**: Create detailed recovery plans.
- **Implementation, Training, and Testing**: Test and train staff.
- **BCP/DRP Maintenance**: Regular updates and improvements.

Disaster Categories:

- **Natural**: Earthquakes, floods, etc.
- **Human**: Intentional (malware, terrorism) or unintentional (employee errors).
- **Environmental (Not to be confused with natural disasters):** Power outages, hardware failures.

Plan Maintenance:

- Update annually or as needed (system changes, gaps identified, leadership changes).

DRP – Disaster Recovery Plan

Our DRP (Disaster Recovery Plan) should answer at least three basic questions:

- What is the objective and purpose?
- Who will be the people or teams who will be responsible in case any disruptions happen?
- What will these people do (our procedures) when the disaster hits?

DRP Lifecycle:

- **Mitigation:** Reduce disaster impact and likelihood.
- **Preparation:** Develop programs, procedures, and tools.
  - **Recovery Considerations:**
    - Evaluate supplier, contractor, and infrastructure impacts.
    - Ensure data center functionality and connectivity.
  - **Simulated Tests:**
    - **DRP Review:** Team reviews plan for gaps.
    - **Read-Through (Checklist):** Managers verify recovery components.
    - **Walkthrough (Tabletop):** Discuss recovery process, identify issues.
    - **Simulation Test:** Simulate disaster response.
  - **Physical Tests:**
    - **Partial Interruption:** Test single application failover.
- **Response:**
  - Quick, effective reaction to disasters.
  - Assess incident severity, notify appropriate staff, involve senior management.
- **Recovery:**
  - Reestablish functionality and return to full production.
  - Engage stakeholders, implement recovery steps (e.g., system rebuilds).

BIA – Business Impact Analysis

Purpose:

- Identify critical and non-critical systems, functions, and activities.
- Determine acceptability based on disruption cost and legal requirements.

Key Metrics:

- **RPO (Recovery Point Objective):** Maximum acceptable data loss.
  - **Example:** Weekly backups imply up to a week of data loss is acceptable.
- **MTD (Maximum Tolerable Downtime):** Total downtime before severe impact.
  - **MTD ≥ RTO + WRT;** includes rebuild and reinsertion time.
  - **Other terms:** MAD (Maximum Allowable Downtime), MTO (Maximum Tolerable Outage), MAO (Maximum Acceptable Outage), MTPoD (Maximum Tolerable Period of Disruption).
- **RTO (Recovery Time Objective):** Time to restore hardware.
  - Must be within MTD limits.
- **WRT (Work Recovery Time):** Time to configure recovered systems.

- **MTBF (Mean Time Between Failures):** Average operational time before failure.
- **MTTR (Mean Time to Repair):** Time to repair failed systems.
- **MOR (Minimum Operating Requirements):** Minimum requirements for critical systems to function.

Recovery Strategies

Redundant Site:
- Identical to production, real-time data copy.
- Automatic failover, geographically distant.
- Most expensive, seamless for end users.

Hot Site:
- Houses critical systems, near real-time data.
- Manual failover, switch in under an hour.
- Smaller than redundant sites.

Warm Site:
- Backup-based data, manual failover.
- Takes 4-24+ hours to switch and restore.

Cold Site:
- Infrastructure only, no hardware or backups.
- Cheapest but longest recovery (weeks+).

Reciprocal Agreement Site:
- Shared space with another organization.
- Promised space or segmented racks.

Subscription/Cloud Site:
- External provider with SLA for recovery.
- Systems with backups, activated on demand.

Mobile Site:
- Data center on wheels, fully equipped.
- May require power and internet hookups.

Lessons Learned
- Review post-disruption or failover test.
- Focus on improvement, not blame.
- Feed insights into BCP and DRP updates.

BCP/DRP Usage
- Activated when other measures fail.
- Critical for business survival (72% closure rate after major data loss).
- Common Pitfalls
  - Lack of senior leadership support.
  - Too narrow scope.
  - Outdated plans, lack of version control.

Plan Maintenance

- Regular updates, iterative process.
- Review and update every 12 months.
- Retrieve and destroy outdated versions, distribute current ones.

Incident Management

Purpose:

- Monitor and respond to security events.
- Ensure predictable, well-understood responses.

Incident Types:

- **Natural**: Earthquakes, floods.
- **Human**: Intentional (malware, terrorism) or unintentional (errors).
- **Environmental (Not to be confused with natural disasters)**: Power outages, hardware failures.

Incident Management Terms

- **Event:**
  - Observable change in system state.
  - **Examples:** System startup, network traffic shift.
- **Alert:**
  - Warning triggered by specific conditions.
  - **Examples:** High traffic utilization, excessive memory usage.
- **Incident:**
  - Multiple adverse events affecting systems or network.
  - Often caused by human actions.
- **Problem:**
  - Incident with unknown cause.
  - Requires root cause analysis for prevention, e.g., internet outage.
- **Inconvenience (Non-disasters):** Minor failures, e.g., hard disk failure, single server down.
- **Emergency (Crisis):** Urgent event potentially risking life or property.
- **Disaster:**
  - Facility unusable for 24+ hours.
  - Mitigated by geographic diversity and redundancy.
  - **Example:** Snowstorm impact.
- **Catastrophe:** Complete destruction of facility.

NIST 800-61 - Incident Response Lifecycle

- **CIRT (Cyber Incident Response Team)**: Includes senior management, incident manager, technical teams, IT security, PR, HR, legal, and auditors.

Incident Lifecycle:

- **Preparation**: Develop policies, train staff, procure detection tools.
- **Detection**: Identify potential security incidents.
- **Response**: Take initial actions to contain incident.

- **Mitigation**: Understand and address the incident's cause.
- **Reporting**: Document incident details and notify management.
- **Recovery**: Restore systems to operational status.
- **Remediation**: Broaden mitigation measures across systems.
- **Lessons Learned**: Analyze and improve future responses.
  - **Root-Cause Analysis:** We attempt to determine the underlying weakness or vulnerability that allowed the incident to happen.

Business Continuity Plan (BCP)

- Long-term plans for continued operations post-disruption.
- **Components**: Includes COOP, Crisis Communications Plan, Critical Infrastructure Protection Plan, Cyber Incident Response Plan, DRP, ISCP, Occupant Emergency Plan.
- **Iterative Process**: Developed with input from key staff and consultants.

Disaster Recovery Plan (DRP)

  - Short-term plans for IT system recovery.
  - Focuses on critical business functions.
  - **Subset of BCP**: Includes system-specific recovery actions.

Disaster Categories

- **Natural**: Earthquakes, floods, tornadoes.
- **Human**: Intentional (malware, terrorism) or unintentional (errors).
- **Environmental (Not to be confused with natural disasters)**: Power outages, hardware failures.

Common Threats and Issues

- **Errors and Omissions (Human)**: Mistakes by employees, often minor but potentially damaging.
- **Electrical/Power Problems (Environmental)**: Power outages and fluctuations; require UPS and generator backups.
- **Environmental Controls**: Manage **heat, pressure, humidity** to protect data centers.
- **Warfare, Terrorism, and Sabotage (Human)**: Internet-based attacks targeting infrastructure.
- **Financially Motivated Attacks (Human)**: Phishing, ransomware, identity theft.
- **Personnel Shortages (Human/Nature/Environmental):**
  - Impact of staff shortages due to natural or health events.
  - Ensure redundancy and plan for critical staff roles.
  - **Travel Security Measures**:
    - Protect data and personnel during travel.
    - Use encryption, monitoring, and VPNs.